

CyberAudit & Solutions

Documentation technique du MVP

Stage 3 — Réutilisable pour le RNCP 5
Développeur Web et Web Mobile

Référent technique	Tommy JOUHANS	Développeur Front-End
Référent technique	James ROUSSEL	Développeur Back-End



Holberton School Dijon — Promotion 2026

Sommaire

1. Introduction

- 1.1 Contexte
- 1.2 Périmètre du document
- 1.3 Public visé
- 1.4 Stack technique

2. User Stories & Mockups

- 2.1 Personas
- 2.2 User Stories priorisées (MoSCoW)
- 2.3 Description des écrans (11 mockups)

3. Architecture du système

- 3.1 Vue d'ensemble — Architecture en couches
- 3.2 Flux de données — Demande d'audit
- 3.3 Choix d'architecture justifiés
- 3.4 Accessibilité (WCAG 2.1 AA)

4. Composants, classes et BDD

- 4.1 Schéma BDD
- 4.2 Diagramme de classes back-end
- 4.3 Composants front-end (React + Tailwind)
- 4.4 Génération du rapport PDF
- 4.5 Monitoring & observabilité

5. Diagrammes de séquence

- 5.1 Inscription + Connexion JWT
- 5.2 Soumission demande d'audit (async)
- 5.3 Génération du rapport PDF (admin)

6. Documentation des APIs

- 6.1 APIs externes consommées
- 6.2 API interne — Endpoints REST

6.3 Conventions transversales

7. Stratégie SCM & QA

7.1 Source Code Management (Git)

7.2 Stratégie QA

7.3 Tests sécurité manuels

7.4 Pipeline CI/CD

7.5 Conformité RGPD

8. Annexes

8.1 Glossaire

8.2 Mapping Stage 3 ↔ RNCP 5

8.3 Sources & références techniques

8.4 Matrice des risques projet

8.5 Liens internes au projet

1. Introduction

1.1 Contexte

CyberAudit & Solutions est une plateforme web full-stack qui connecte les PME/TPE françaises sans équipe IT interne avec des experts en cybersécurité. Selon l'ANSSI 2023, 45 % des PME n'ont aucune équipe informatique dédiée et restent exposées à des cyberattaques (ransomware, phishing, fuite de données).

1.2 Périmètre du document

Cette documentation technique couvre la conception détaillée du MVP. Elle décrit :

- Les besoins utilisateurs formalisés en User Stories priorisées
- L'architecture logicielle et le flux de données
- Le modèle de données (PostgreSQL relationnel)
- Les classes back-end, composants front-end, scénarios d'interaction
- Les APIs exposées et consommées
- La stratégie de gestion du code et de qualité

1.3 Public visé

- Équipe de développement (Tommy + James) — référence pendant la phase de codage (W2 → W12)
- Jury Holberton — preuve de la conception détaillée du MVP
- Jury RNCP 5 — dossier de compétences réutilisable pour la certification Développeur Web et Web Mobile

1.4 Stack technique

Couche	Technologie	Justification
Front-End	React 18 + Tailwind CSS	SPA performante, design system rapide
Back-End	Django 5 + DRF	Sécurité native, écosystème mature
BDD	PostgreSQL 15	Relationnel ACID, index performants
Async	Celery + Redis	Tâches longues hors thread HTTP
Auth	SimpleJWT	Stateless, scalable
Hébergement	Vercel + Railway	HTTPS auto, déploiement Git

2. User Stories & Mockups

2.1 Personas

Marie — 45 ans, gérante d'un cabinet comptable à Dijon, aucune notion IT. Cible UX < 3 min.

Karim — 32 ans, expert cybersécurité, gère la file de demandes en parallèle.

2.2 User Stories priorisées (MoSCoW)

Must Have

ID	User Story	Stage
US-01	En tant que visiteur, je veux m'inscrire, afin de créer mon compte.	W3
US-02	En tant qu'utilisateur, je veux me connecter, afin d'accéder à mon espace.	W3
US-03	En tant qu'utilisateur, je veux me déconnecter, afin de protéger mon compte.	W3
US-04	En tant que cliente PME, je veux soumettre une demande en < 3 min.	W4
US-05	En tant que cliente, je veux suivre le statut (4 statuts).	W4
US-06	En tant que cliente, je veux recevoir un email à chaque changement.	W4
US-07	En tant qu'admin, je veux voir toutes les demandes triées.	W5
US-08	En tant qu'admin, je veux changer le statut.	W5
US-09	En tant qu'admin, je veux générer un PDF.	W5
US-10	En tant que cliente, je veux télécharger mon PDF.	W5

Should Have

US-11 modules sensibilisation • US-12 reset MDP • US-13 filtres admin • US-14 notifications UI.

Could Have / Won't Have

US-15 à US-17 (V2). Hors périmètre : app mobile, score IA, marketplace, OAuth2, gamification.

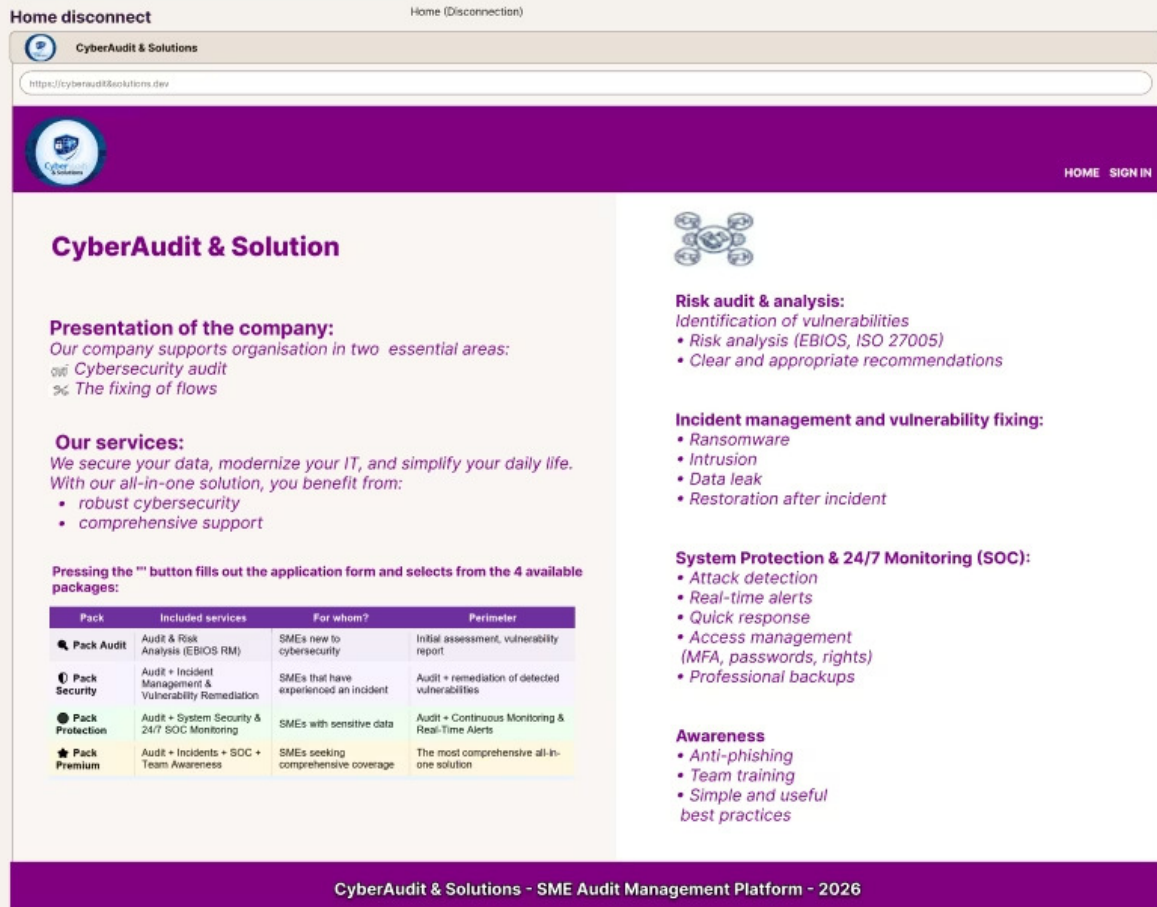
2.3 Description des écrans (11 mockups Figma à produire en W1)

Écran 1 — Landing publique

Hero (problème ANSSI), CTA, bénéfices. La page d'accueil de la plateforme CyberAudit & Solutions présente l'entreprise, les prestations de services et les packs proposés adaptés aux entrepreneurs de moins de 50 salariés. Il suffit d'aller sur l'onglet « SIGN IN » pour que la cliente (Marie) puisse créer un compte et se connecter.

1. Public Access & Authentication

Screens visible before login: public home, login/registration, logged-in home



Mockup 1 — Landing publique

Écran 2 — Inscription

Email + MDP + CGU/RGPD. Après avoir cliqué sur « Create an account », la cliente renseigne le nom de son entreprise, son prénom, son nom, son email et son mot de passe (haché). Règles de remplissage :

- Chaque champ contient au maximum 50 caractères
- Si une case est manquante : erreur « veuillez saisir l'information sur le formulaire »
- Email format `nom@domaine` obligatoire
- Mot de passe : une minuscule, une majuscule, un chiffre, un caractère spécial, minimum 10 caractères

Create an account

Log in

CyberAudit & Solutions

https://cyberaudit&solutions.dev

CyberAudit & Solutions

HOME SIGN IN



Create an account

Fill in the information below to get started

Company Name

Enter company name

First Name

Enter first name

Last Name

Enter last name

Email

Enter email address

Password

Create a password

Create an account

Already have an account?

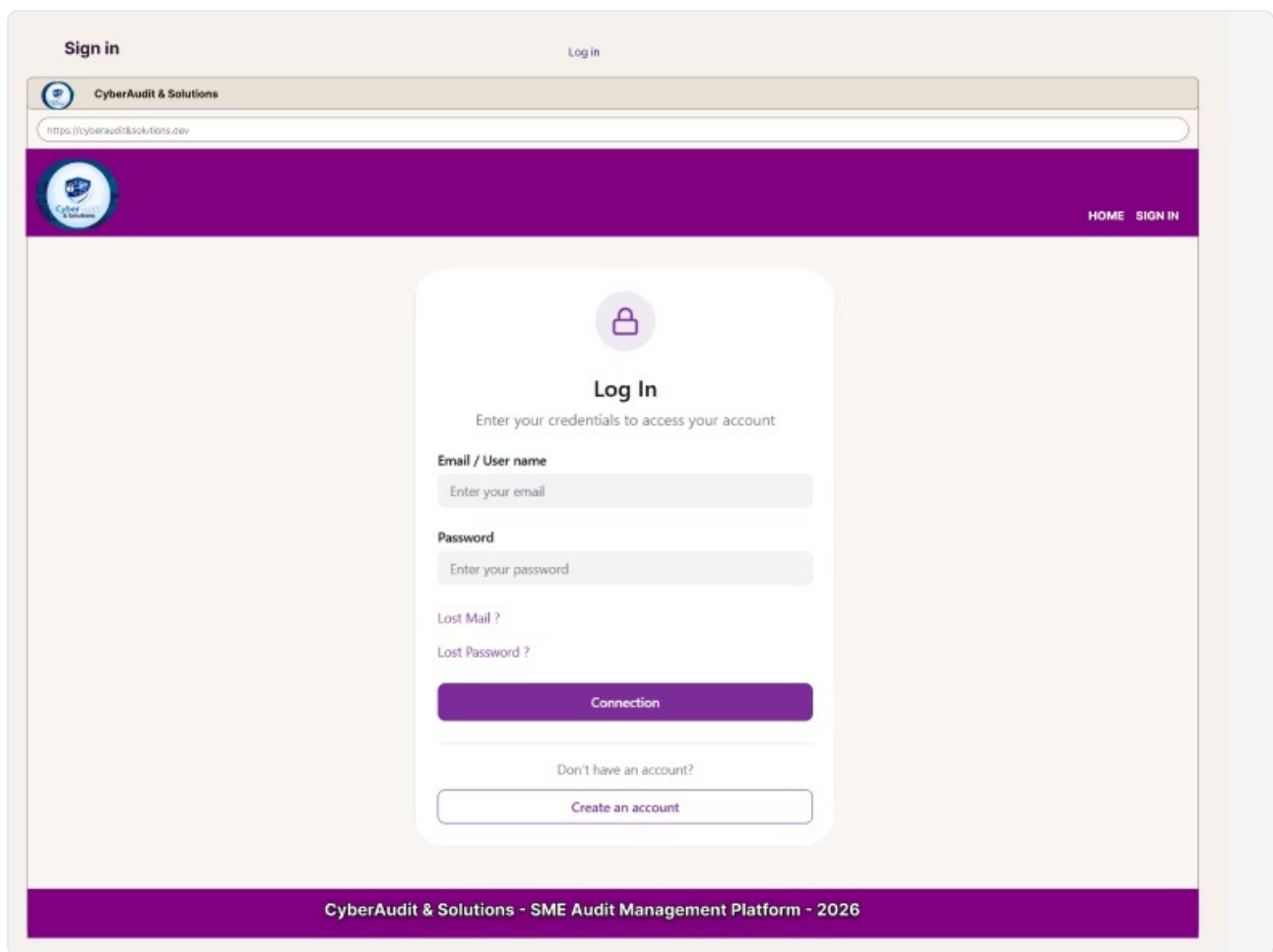
Sign In

CyberAudit & Solutions - SME Audit Management Platform - 2026

Mockup 2 — Inscription

Écran 3 — Connexion

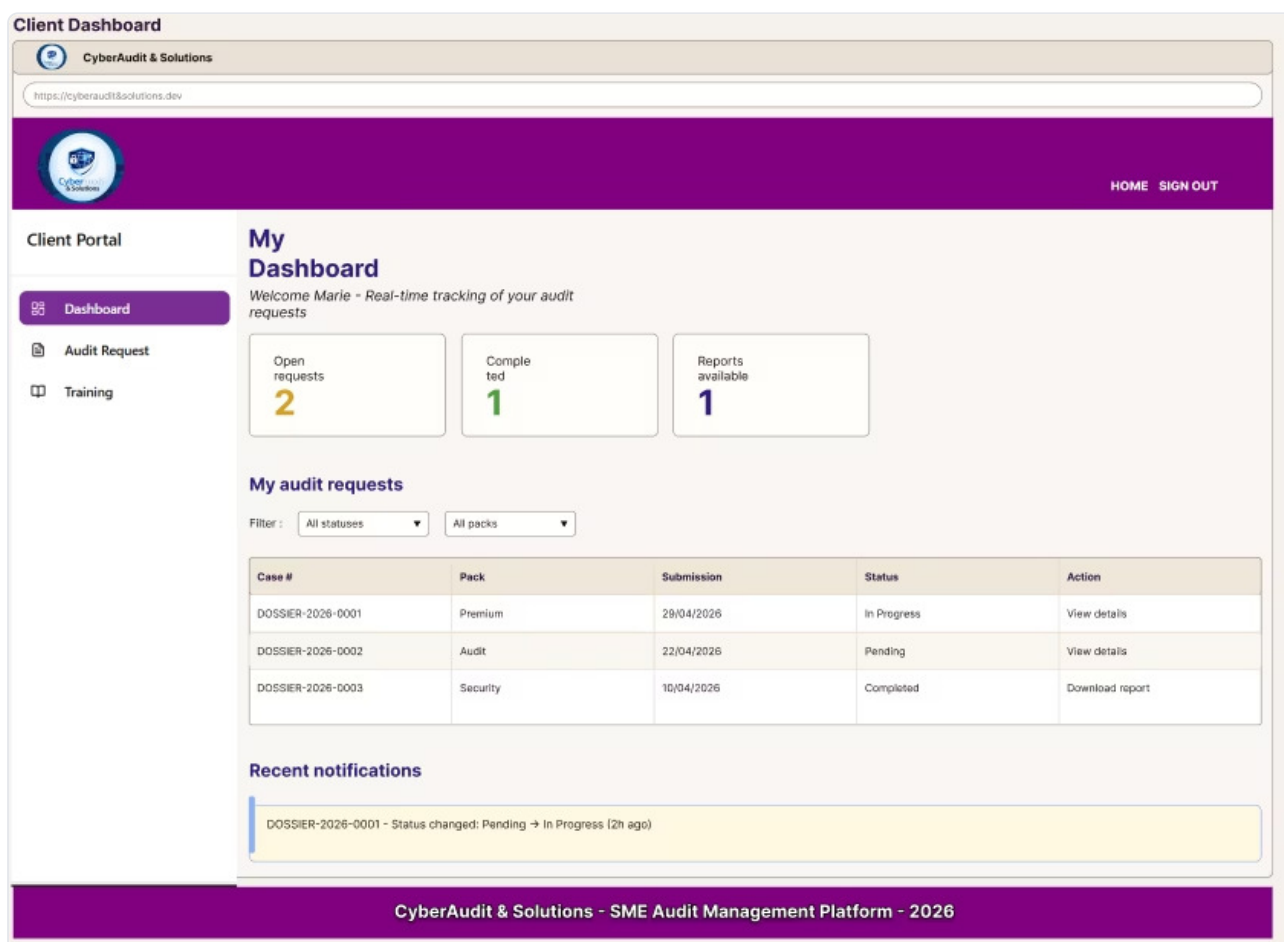
Email + MDP. La cliente peut se connecter avec son compte ; sinon elle clique sur « Create an account ». Liens « Lost Mail » et « Lost Password » prévus (à développer ultérieurement pour la présentation RNCP 5).



Mockup 3 — Connexion

Écran 4 — Dashboard Client

Sidebar, liste de demandes, CTA flottant. Lorsque la cliente est connectée, elle consulte son tableau de bord pour suivre l'avancement de sa demande d'audit (En attente / En cours / Terminé). Elle peut cliquer sur « View details » et télécharger le rapport via « Download report ».



Mockup 4 — Dashboard Client

Écran 5 — Formulaire d'audit

Stepper 3 étapes, cible < 3 min. La cliente renseigne nom d'utilisateur, nom d'entreprise, choix du pack (Audit / Security / Protection / Premium) avec affichage des « Services inclus », et un message optionnel. Bouton « Send the Audit Request » pour envoyer.

The screenshot displays the 'CyberAudit & Solutions' Client Portal. The header includes the company logo, name, and a URL bar showing 'https://cyberaudit&solutions.dev'. A navigation bar at the top right contains 'HOME' and 'SIGN OUT' links. A left sidebar menu lists 'Dashboard', 'Audit Request' (highlighted), and 'Training'. The main content area is titled 'Audit request form' and contains the following fields and options:

- Username :** [Text input field]
- Company Name :** [Text input field]
- Select pack :**
 - ☒ Pack Audit
 - ☐ Pack Security
 - ☐ Pack Protection
 - ☐ Pack Premium
- Included Services:**

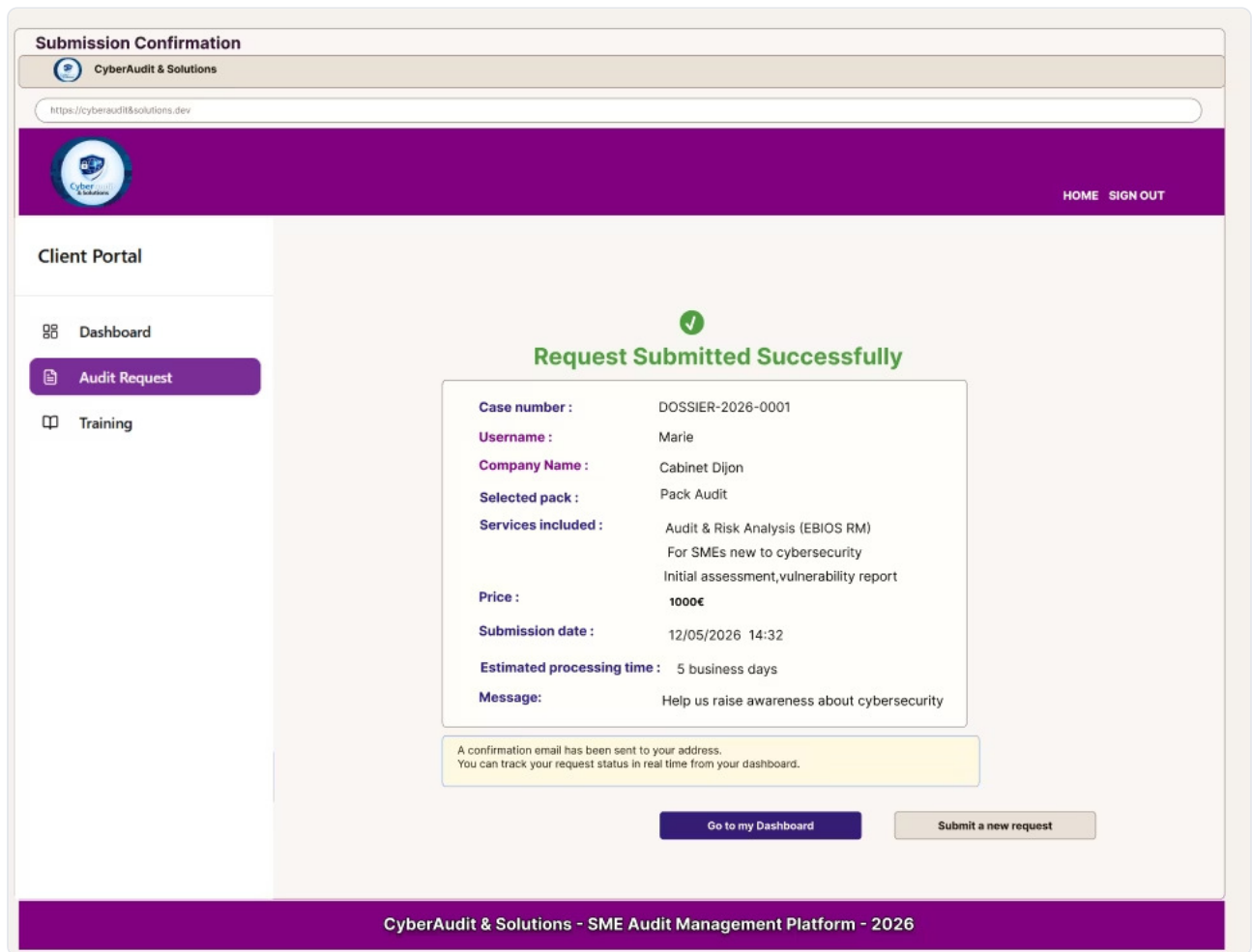
Print in the panel of included services of the selected package such as:
If you select "Audit & Risk"
Display for example:
Analysis (EBIOS RM) | SMEs new to cybersecurity | Initial assessment, vulnerability report | 5 business day | Price: 1000 €
- Message :** [Text input field]
- Sent the audit request** [Submit button]

The footer of the page reads: 'CyberAudit & Solutions - SME Audit Management Platform - 2026'.

Mockup 5 — Formulaire d'audit (3 étapes)

Écran 6 — Détail demande (client)

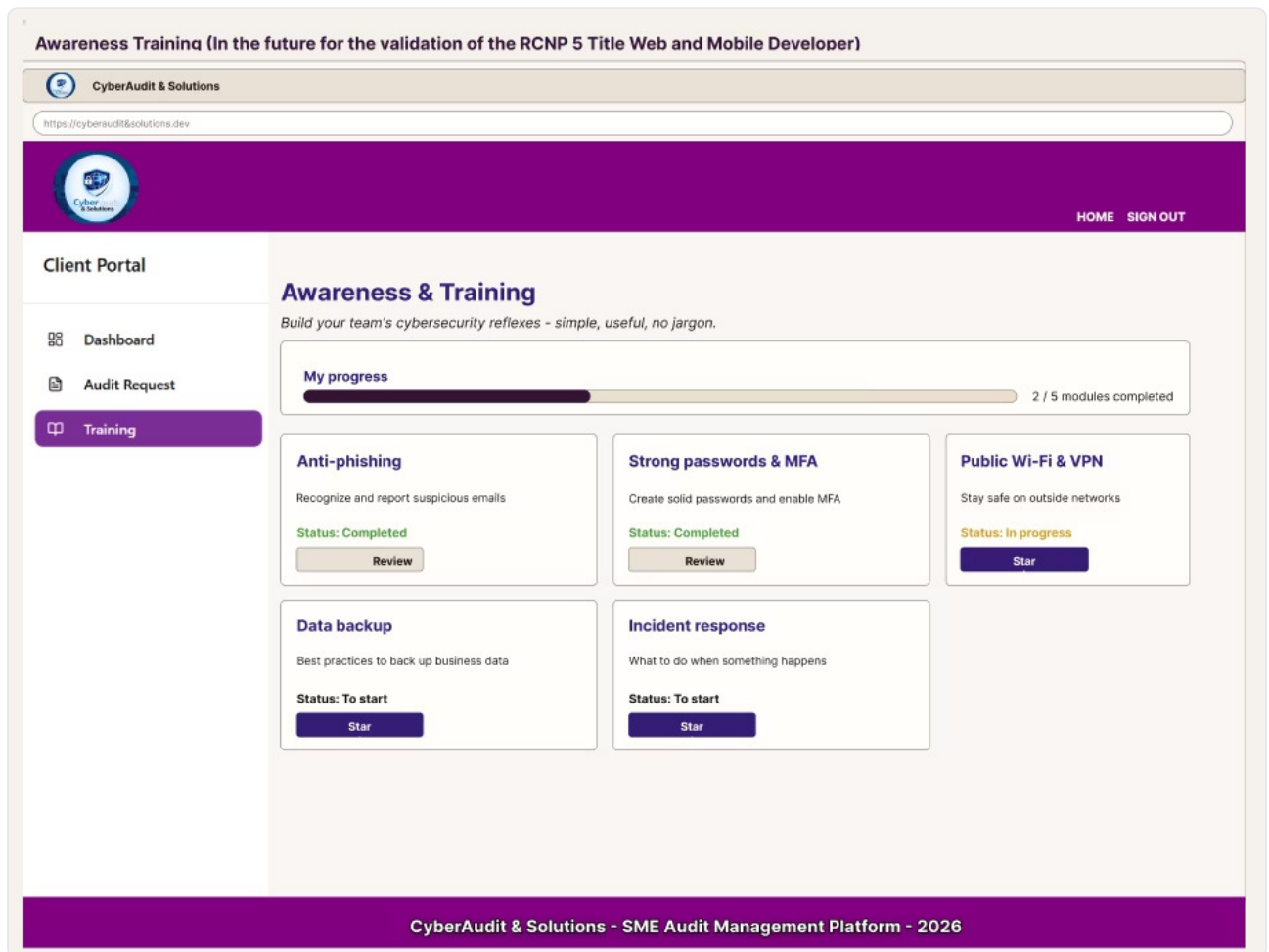
Statut, timeline. Après envoi, message de confirmation à l'expert (Karim) et accusé de réception à la cliente. La cliente suit l'avancée de l'analyse.



Mockup 6 — Détail demande côté client

Écran 7 — Module formations

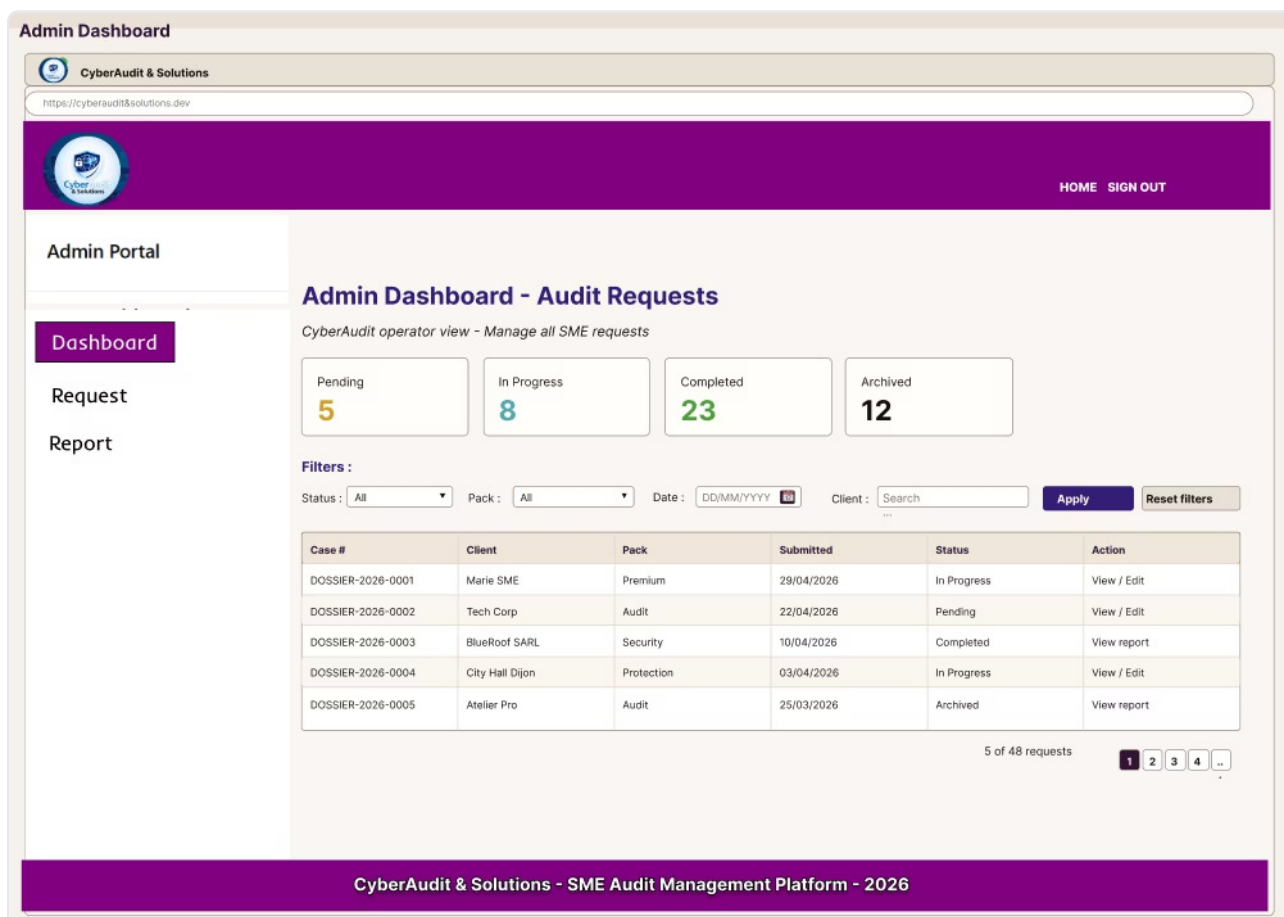
Liste cartes + détail markdown. (À développer ultérieurement). Modules : « anti-phishing », « Authentification à facteurs multiples », « Connexion publique et Wi-Fi & VPN », « Sauvegarde de données », « Réponse d'incidents ». Sous différents formats (vidéo, visio, documentation) avec barre de progression.



Mockup 7 — Modules de formation

Écran 8 — Dashboard Admin

Tableau + filtres. L'expert (Karim) accède à son tableau de bord avec toutes les demandes. Il peut trier la liste selon le pack choisi et les états actuels, puis consulter et éditer chaque demande.



Mockup 8 — Dashboard Admin

Écran 9 — Détail demande (admin)

Sélecteur statut + bouton générer. En cliquant sur « View/edit », Karim change le statut via le formulaire « Status & Actions », génère un rapport PDF via « Generate PDF report », envoie une notification au client (« Send notification ») et peut archiver la demande (« Archive request »).

Admin Request Detail

CyberAudit & Solutions

https://cyberauditsolutions.dev

HOME SIGN OUT

Admin Portal

Dashboard

Request

Report

Request DOSSIER-2026-0001

Back to list

Client information

Company :

Marie SME (Cabinet Comptable)

Contact :

Marie Dupont

Email :

marie@cabinet-dijon.fr

Submitted :

29/04/2026 at 14:32

Pack selected :

Pack Audit

Client message :

Help us raise awareness about cybersecurity

Status & Actions

Current status :

In Progress

Assigned to :

Karim

Internal notes

EBIOS RM analysis ongoing. Awaiting client log files.

Save changes

Generate PDF report

Send notification

Archive request

History (immutable - GDPR)

Date	Author	Action
29/04/2026 14:32	Marie Dupont	Request submitted (Pack Premium)
29/04/2026 14:32	System	Confirmation email sent (Celery)
29/04/2026 16:10	Karim	Status changed: Pending -> In Progress
29/04/2026 16:11	Karim	Internal note added

CyberAudit & Solutions - SME Audit Management Platform - 2026

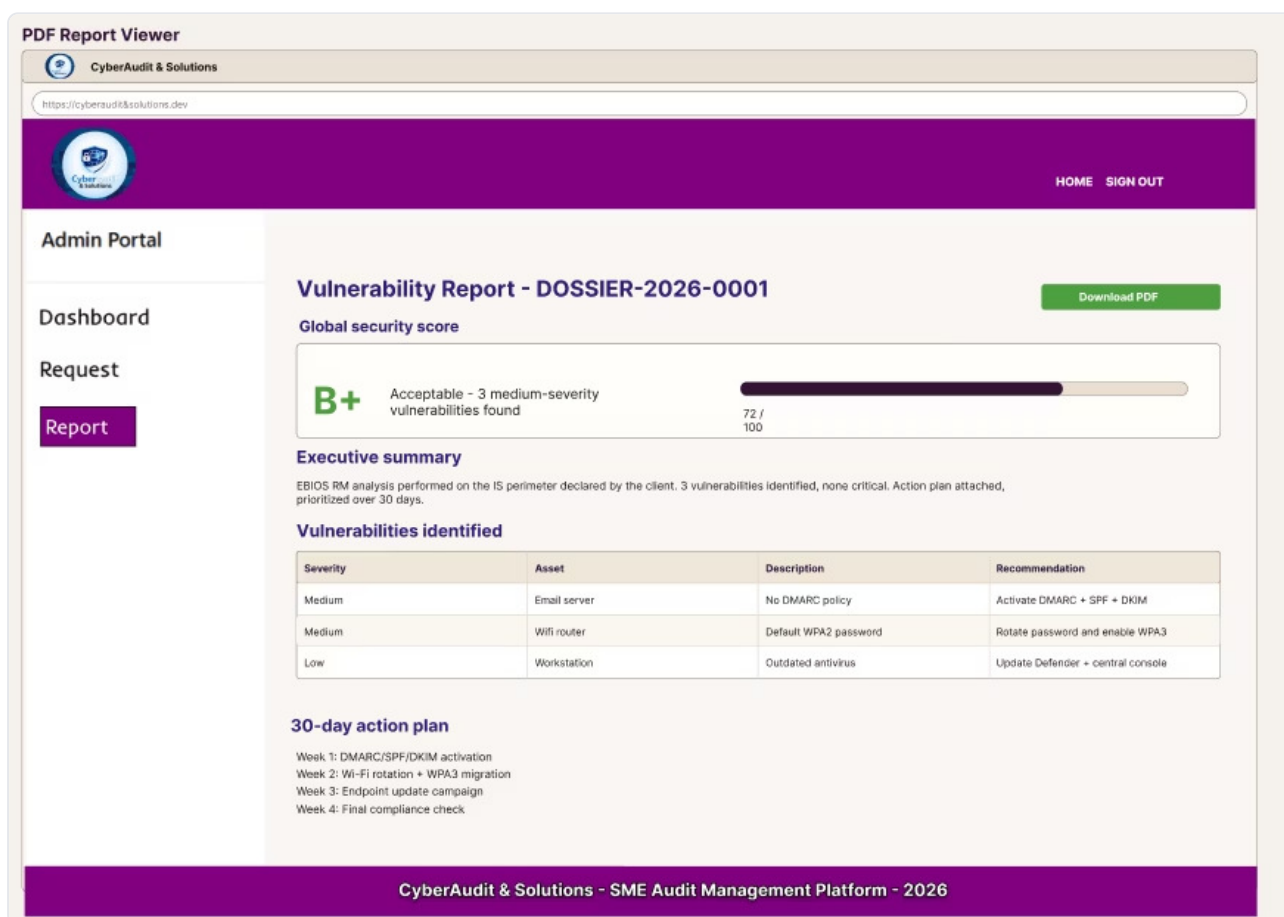
Mockup 9 — Détail demande côté admin

Écran 10 — Visionneuse de rapports PDF

Rapport peut être téléchargé. Le rapport identifie :

- Le niveau de vulnérabilités (Low, Medium, High)
- Les atouts (serveur mail, routeur wifi, etc.)
- La description
- Les recommandations

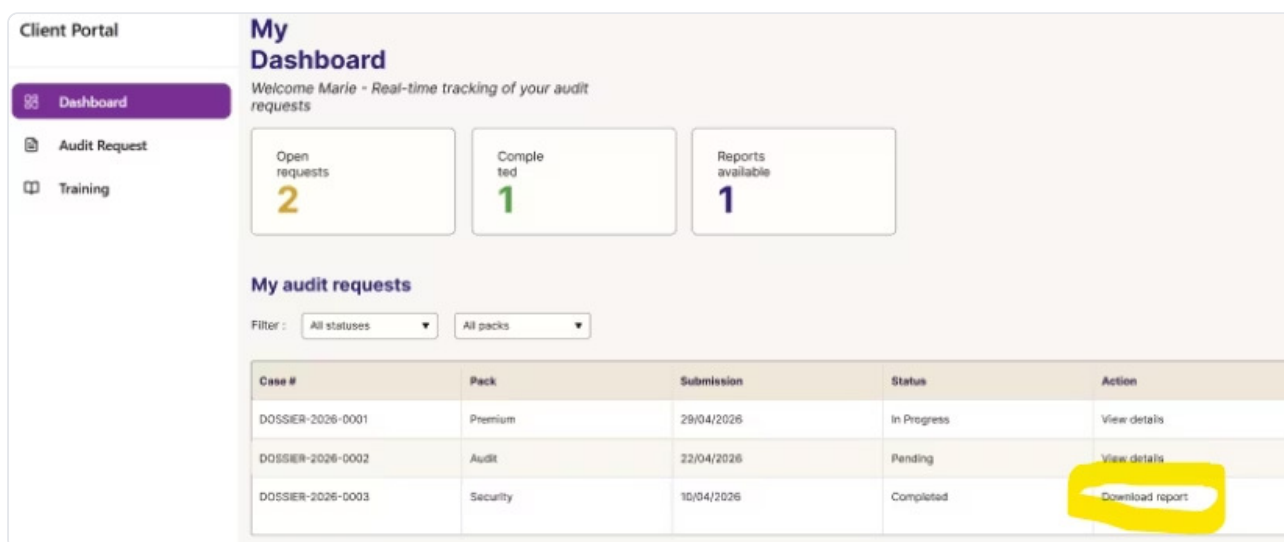
Un plan d'action est généré avec le nombre de jours estimé.



Mockup 10 — Visionneuse de rapport PDF

Écran 11 — Téléchargement depuis le dashboard

Le client peut télécharger le rapport depuis son tableau de bord via le lien « Download report ».



Mockup 11 — Téléchargement depuis le dashboard

3. Architecture du système

3.1 Vue d'ensemble — Architecture en couches

L'architecture suit un modèle en couches : Client (navigateur) → CDN/Backend → Données + Services externes.

- **Client (Navigateur)** : React SPA · Tailwind CSS · DOMPurify (anti-XSS), HTTPS, REST + JWT
- **Vercel / CDN** : Assets statiques · HTTPS Let's Encrypt
- **Back-End (Railway / Render)** : Django REST API (JSON, JWT, HTTPS) — Celery Worker (async) — Redis (broker) — ORM — SMTP
- **Couche données** : PostgreSQL 15 + Storage PDFs
- **Services externes** : SMTP Gmail (notifications email)

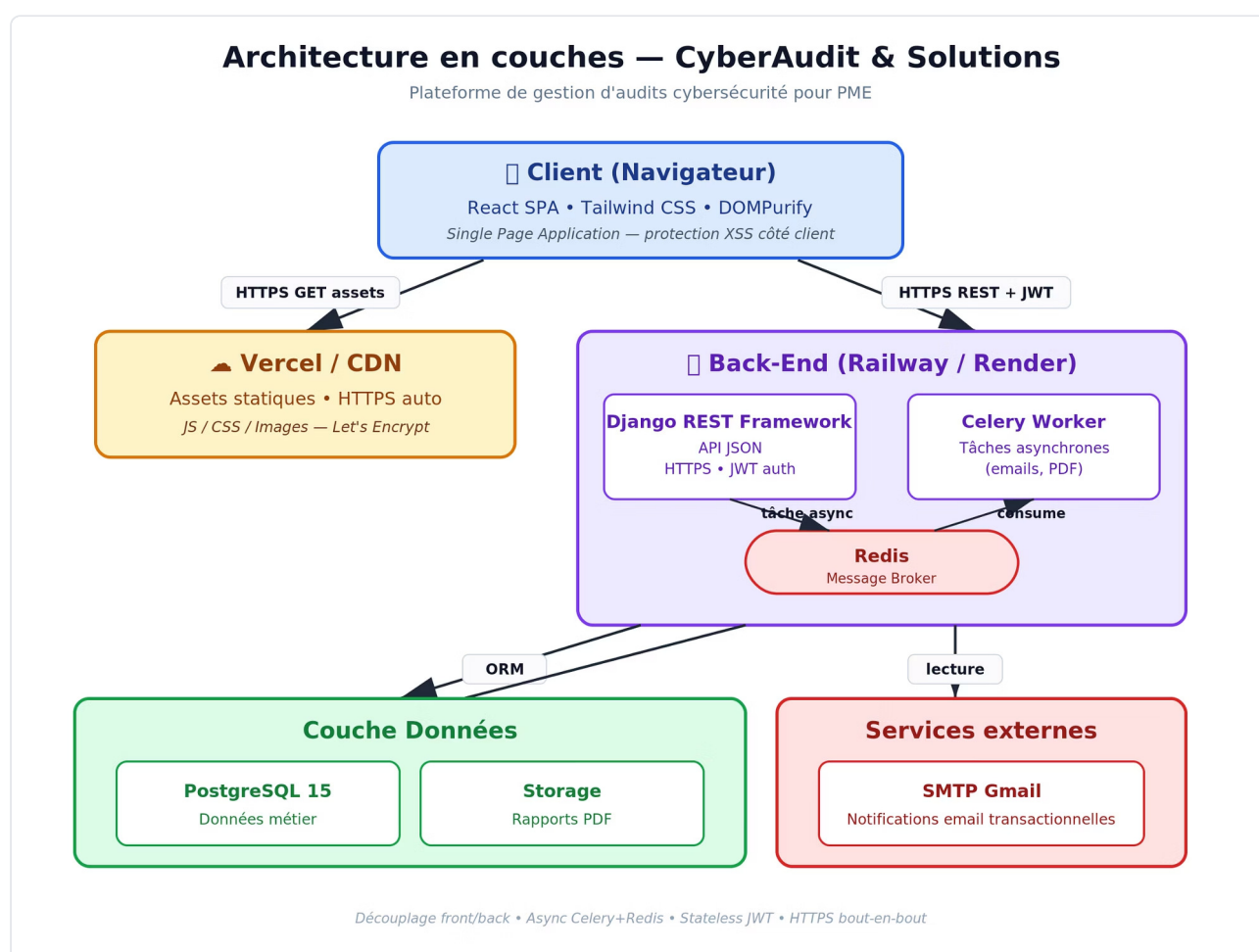


Figure 1 — Architecture en couches : Client → CDN/Backend → Données + Services externes

3.2 Flux de données — Demande d'audit

1. Marie remplit le formulaire dans la SPA React.
2. Le front envoie `POST /api/audits/` (JSON + JWT dans `Authorization: Bearer`).
3. Django valide la requête (DRF serializer) et persiste en BDD via l'ORM.
4. Django publie une tâche Celery `send_acknowledgment_email(audit_id)` dans Redis.

5. Django répond `201 Created` avec le détail de l'audit.
6. Karim (admin) voit la nouvelle demande dans son dashboard (polling 30 s — V2 : WebSocket).

3.3 Choix d'architecture justifiés

- **Découplage front/back** → 2 déploiements indépendants, CORS contrôlé, SPA cacheable sur CDN.
- **Async Celery** → la génération d'un PDF peut prendre 5-10 s ; on ne bloque pas le thread HTTP.
- **PostgreSQL relationnel** → données fortement structurées avec relations (User → AuditRequest → Report), intégrité ACID critique.
- **JWT stateless** → pas de session serveur, scalable horizontalement.

3.4 Accessibilité (WCAG 2.1 niveau AA)

La cible utilisatrice prioritaire (Marie, 45 ans, non-IT) impose un parcours accessible. La plateforme vise la conformité **WCAG 2.1 niveau AA** sur les 4 principes : perceptible, utilisable, compréhensible, robuste.

3.4.1 Règles appliquées

Principe WCAG	Mise en œuvre
Contraste minimal	Ratio 4.5:1 sur le texte normal, 3:1 sur le texte large. Palette <code>cyber-700</code> (<code>#5b21b6</code>) sur fond blanc validée — outil de vérification : <code>axe DevTools</code> .
Navigation clavier	Tous les éléments interactifs accessibles via <code>Tab</code> / <code>Shift+Tab</code> . Ordre logique de focus respectant la lecture. <code>:focus-visible</code> Tailwind avec anneau violet 2px sur chaque CTA.
ARIA labels	<code>StatusBadge</code> expose <code>aria-label="Statut : en cours"</code> . <code>SecurityScoreGauge</code> expose <code>role="meter"</code> + <code>aria-valuenow</code> . Icônes décoratives en <code>aria-hidden="true"</code> .
Formulaires	Chaque <code><input></code> a un <code><label></code> associé (pas seulement un placeholder). Messages d'erreur reliés via <code>aria-describedby</code> . Champs requis annoncés avec <code>aria-required</code> .
Structure sémantique	Balises <code><header></code> , <code><nav></code> , <code><main></code> , <code><footer></code> , hiérarchie de titres <code>h1</code> → <code>h6</code> sans saut. Skip-link "Aller au contenu" en première position.
Images et icônes	Attribut <code>alt</code> systématique : descriptif si informatif, vide si décoratif. Diagrammes d'architecture proposés en SVG accessible + description textuelle équivalente.
Multilingue	Attribut <code>lang="fr"</code> sur <code><html></code> . Aucun contenu mélangeant FR/EN sans changement de <code>lang</code> .
Animations	Respect de <code>prefers-reduced-motion</code> via media query Tailwind : transitions désactivées si l'utilisateur le demande dans son OS.

3.4.2 Tests d'accessibilité automatisés

- **axe-core** intégré aux tests Vitest : `npm install -D @axe-core/react jest-axe`. Chaque composant majeur (LoginForm, AuditRequestForm, RequestTable) testé via `expect(await axe(container)).toHaveNoViolations()`.
- **Lighthouse CI** dans le pipeline GitHub Actions : score Accessibilité ≥ 90 obligatoire pour merge.
- **Tests manuels W7-W10** : navigation 100 % clavier sur les 3 parcours critiques (inscription, soumission audit, téléchargement PDF), test lecteur d'écran avec NVDA (Windows) et VoiceOver (macOS).

3.4.3 Cible mesurable

Score Lighthouse Accessibilité $\geq 90/100$ sur les 4 pages principales (landing, login, dashboard client, formulaire audit) avant la soutenance W12.

4. Composants, classes et BDD

4.1 Schéma BDD

Entité	Champs clés	Relations
USER	id (UUID), email (UK), password_hash, first_name, last_name, role (client/admin), company_name, created_at, is_active	1→N AuditRequest (submits / follows / receives)
AUDIT_PACK	id, reference, code (audit/security/protection/premium), name, description, duration_days, price	1→N AuditRequest (chosen_by)
AUDIT_REQUEST	id (UUID), client_id (FK), pack_id (FK), status (pending/in_progress/done/archived), scope_notes, submitted_at, updated_at, completed_at	N→1 User+Pack ; 1→1 Report ; 1→N Notification
AUDIT_REPORT	id (UUID), audit_request_id (FK UK), pdf_path, summary, findings (JSON), generated_at	1→1 AuditRequest
TRAINING_MODULE	id, title, content_md, duration_min, level, published_at	1→N Progress
TRAINING_PROGRESS	id, user_id, module_id, completed, started_at, completed_at	N→1 User + Module
NOTIFICATION	id, user_id, request_id, type, subject, status, sent_at	N→1 User + Request

Index recommandés :

- `USER.email` UNIQUE
- `AUDIT_REQUEST.status` BTREE (filtrage admin fréquent)
- (`AUDIT_REQUEST.client_id` , `AUDIT_REQUEST.created_at`) composé (dashboard client)
- `AUDIT_REPORT.audit_request_id` UNIQUE (1 rapport par demande)

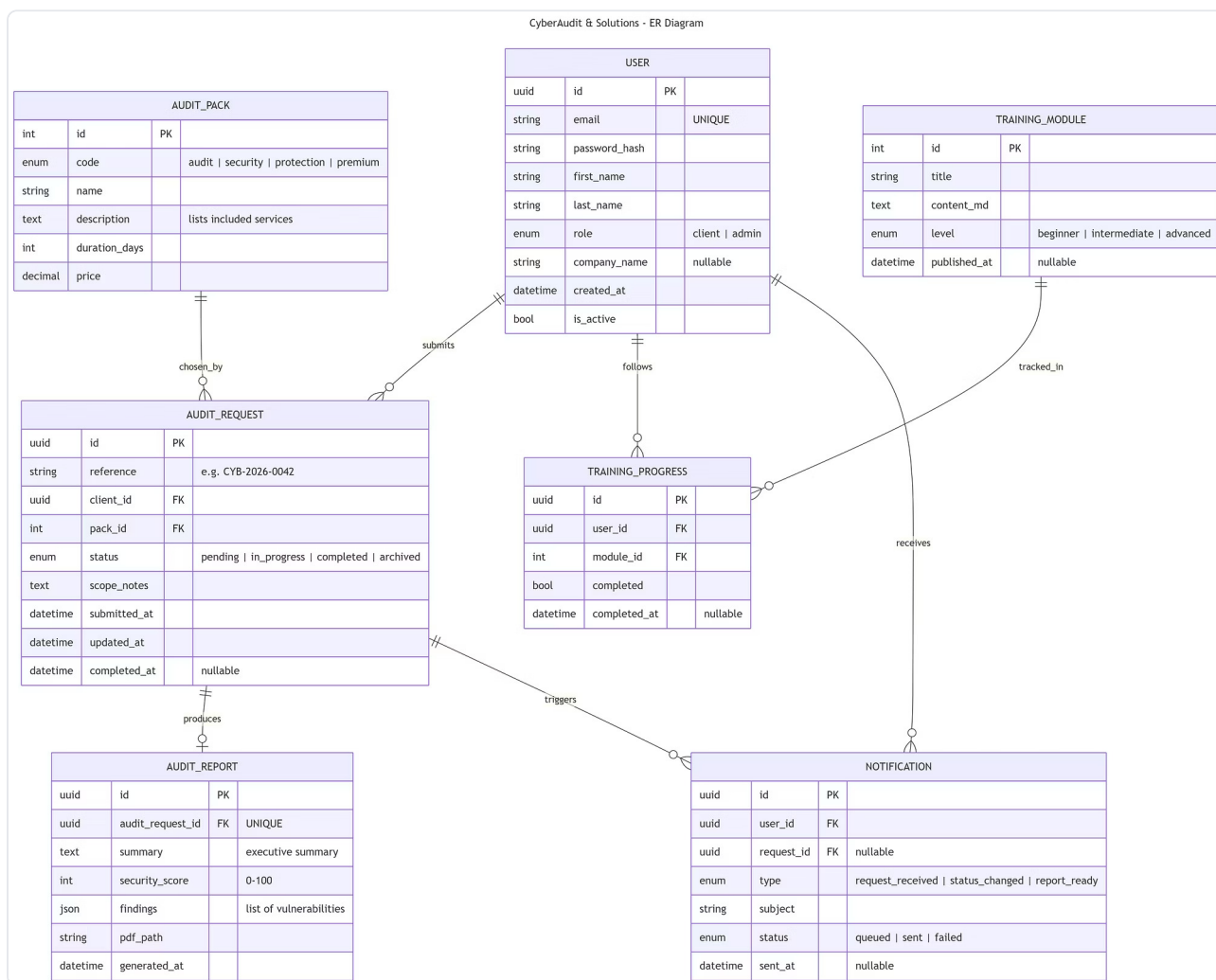


Figure 2 — Schéma relationnel de la base de données

4.2 Diagramme de classes back-end (Django models + services)

Classe User

Représente un utilisateur de la plateforme, qu'il soit client SME ou administrateur. Gère l'authentification JWT et la séparation des rôles.

Attribut	Description
<code>id : UUID</code>	Identifiant unique (PK)
<code>email : str</code>	Adresse e-mail (unique, indexée)
<code>_password_hash : str</code>	Mot de passe haché (bcrypt / PBKDF2)
<code>first_name, last_name</code>	Prénom et nom
<code>role : enum</code>	client ou admin
<code>company_name : str</code>	Nom de l'entreprise (nullable)
<code>is_active : bool</code>	Compte activé ou désactivé
<code>created_at : datetime</code>	Date de création du compte

Méthodes : `check_password(raw)`, `has_role(role)`

Classe AuditPack

Représente l'un des 4 packs (Audit, Security, Protection, Premium). Données de référence chargées via fixture.

<code>id : int</code>	Identifiant unique
<code>code : enum</code>	audit / security / protection / premium
<code>name : str</code>	Nom commercial
<code>description : str</code>	Liste des services inclus
<code>duration_days : int</code>	Délai estimé de traitement
<code>price : Decimal</code>	Tarif du pack

Classe AuditRequest

Cœur du métier : la demande d'audit soumise par un client SME. Cycle de 4 statuts (pending → in_progress → completed → archived).

<code>id : UUID</code>	Identifiant unique
<code>reference : str</code>	Numéro de dossier (ex : CYB-2026-0042)
<code>client_id : FK → User</code>	Client SME ayant soumis
<code>pack_id : FK → AuditPack</code>	Pack choisi
<code>status : enum</code>	pending / in_progress / completed / archived
<code>scope_notes : str</code>	Précisions du formulaire
<code>submitted_at, completed_at</code>	Dates de cycle

Méthodes : `generate_reference()`, `update_status(new_status)`, `estimated_completion()`

Classe AuditReport

Rapport de vulnérabilités lié à une seule AuditRequest, inclut un score visuel et un PDF téléchargeable.

<code>id : UUID</code>	Identifiant unique
<code>audit_request_id : FK</code>	Relation 1-1
<code>summary : str</code>	Résumé exécutif vulgarisé
<code>security_score : int</code>	Score 0-100 (jauge)
<code>findings : JSON</code>	Liste des vulnérabilités
<code>pdf_path : str</code>	Chemin du PDF généré
<code>generated_at</code>	Date de génération

Méthodes : `build_pdf()`, `get_download_url()`

Classe Notification

Trace toutes les communications e-mail envoyées via Celery.

id : UUID	Identifiant unique
user_id : FK → User	Destinataire
request_id : FK	Demande concernée (nullable)
type : enum	request_received / status_changed / report_ready
status : enum	queued / sent / failed

Méthodes : send(), retry()

Classes TrainingModule & TrainingProgress

Modules de sensibilisation cybersécurité (phishing, MFA, RGPD...) avec suivi de progression utilisateur.

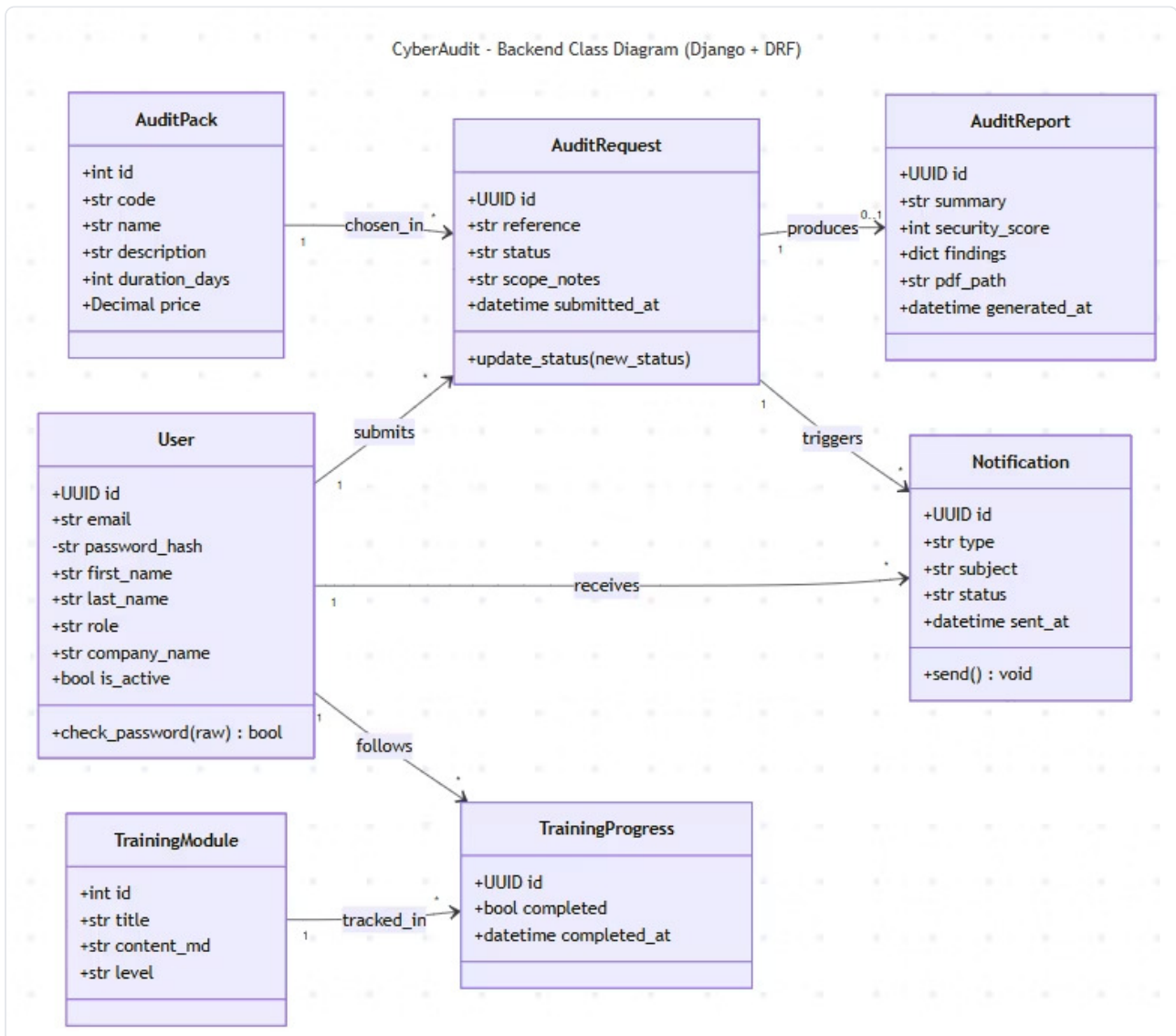


Figure 3 — Diagramme de classes back-end Django

Exemple — `accounts/models.py`

```
class User(AbstractBaseUser, PermissionsMixin):
    """Utilisateur de la plateforme – client PME ou admin CyberAudit."""
    id = UUIDField(primary_key=True, default=uuid4)
    email = EmailField(unique=True, db_index=True)
    role = CharField(choices=[('client', 'Client'), ('admin', 'Admin')])
    company_name = CharField(max_length=200, blank=True)
    company_size = CharField(choices=[('TPE', 'TPE'), ('PME', 'PME'), ('ETI', 'ETI')])
    sector = CharField(max_length=100, blank=True)
    is_active = BooleanField(default=True)
    created_at = DateTimeField(auto_now_add=True)
    last_login = DateTimeField(null=True)

    USERNAME_FIELD = 'email'
    REQUIRED_FIELDS = []

    def is_admin(self) -> bool: ...
    def is_client(self) -> bool: ...
```

Exemple — `audits/models.py`

```
class AuditPack(models.Model):
    """Catalogue des 4 packs d'audit proposés."""
    name = CharField(max_length=50)
    description = TextField()
    duration_days = PositiveIntegerField()
    price = DecimalField(max_digits=8, decimal_places=2)

class AuditRequest(models.Model):
    """Demande d'audit soumise par un client."""
    STATUS_CHOICES = [
        ('pending', 'En attente'),
        ('in_progress', 'En cours'),
        ('done', 'Terminé'),
        ('archived', 'Archivé'),
    ]
    id = UUIDField(primary_key=True, default=uuid4)
    client = ForeignKey(User, on_delete=PROTECT, related_name='audit_requests')
    pack = ForeignKey(AuditPack, on_delete=PROTECT)
    status = CharField(choices=STATUS_CHOICES, default='pending',
db_index=True)
    scope_notes = TextField(blank=True)
    created_at = DateTimeField(auto_now_add=True)
    updated_at = DateTimeField(auto_now=True)
    completed_at = DateTimeField(null=True, blank=True)

    def transition_to(self, new_status: str) -> None:
        """Change le statut, met à jour completed_at et déclenche la notification."""
        ...
```

```
def can_generate_report(self) -> bool:
    return self.status == 'done'
```

Services métier (logique séparée des modèles)

```
# audits/services.py
class AuditRequestService:
    @staticmethod
    def create_request(client: User, pack_id: int, scope: str) -> AuditRequest: ...

    @staticmethod
    def change_status(request: AuditRequest, new_status: str, by: User) -> None:
        """Change le statut + déclenche email Celery."""
        ...

# reports/services.py
class PDFReportGenerator:
    @staticmethod
    def generate(audit_request: AuditRequest) -> AuditReport:
        """Génère un PDF avec WeasyPrint, stocke le chemin, persiste."""
        ...

# notifications/tasks.py (Celery)
@shared_task
def send_status_change_email(audit_id: str, new_status: str) -> None: ...
```

4.3 Composants front-end (React + Tailwind CSS)

Le front-end est une SPA React communiquant avec l'API REST via JWT. L'arborescence se structure en pages (vues complètes), composants UI réutilisables, store global et services d'appel API.

Authentification & routage

AuthStore — State global : `user`, `accessToken`, `refreshToken`. Méthodes : `login`, `logout`, `refresh`, `hasRole`.

ProtectedRoute — Composant de garde, props : `allowedRoles`. Redirige vers `/login` si non authentifié.

ApiClient — Wrapper axios qui ajoute automatiquement le JWT à chaque requête et gère le refresh token en cas de 401.

Pages publiques

LoginPage — Formulaire de connexion. Soumet à `AuthStore.login()` puis redirige selon le rôle.

RegisterPage — Formulaire d'inscription client SME. Appelle `AuthStore.register()`.

Espace client SME

ClientDashboard — Tableau de bord listant les demandes du client connecté.

AuditRequestForm — Formulaire en 3 étapes (pack, périmètre, confirmation). Affiche 4 PackCard.

RequestDetail — Vue détaillée avec timeline, rapport PDF, score. Composants : `StatusBadge`, `SecurityScoreGauge`, `FindingsList`.

Espace administrateur CyberAudit

AdminDashboard — Vue paginée de toutes les demandes avec filtres (statut, pack, date, client) et tri.

Module de formation

TrainingPage — Liste des modules avec indicateur de progression.

TrainingModuleViewer — Affiche le contenu Markdown. Sécurité : nettoyage via DOMPurify (anti-XSS, SMART #3).

Composants UI réutilisables

Navbar, **PackCard**, **StatusBadge** (gris/bleu/vert/violet), **SecurityScoreGauge** (jauge circulaire, rouge < 40, orange 40-70, vert > 70), **RequestTable**, **Pagination**, **ToastContainer**.

Flux d'interaction principal — Soumission demande

1. L'utilisateur se connecte via LoginPage → AuthStore stocke le JWT.
2. ProtectedRoute autorise l'accès au ClientDashboard.
3. Clic sur « Nouvelle demande » → AuditRequestForm charge les packs.
4. Sélection d'une PackCard → AuditService.create() appelle l'API Django.
5. Le back-end crée l'AuditRequest et déclenche la tâche Celery d'email.
6. Le client est redirigé vers RequestDetail (StatusBadge "pending").
7. À chaque changement de statut côté admin, une Notification est envoyée.

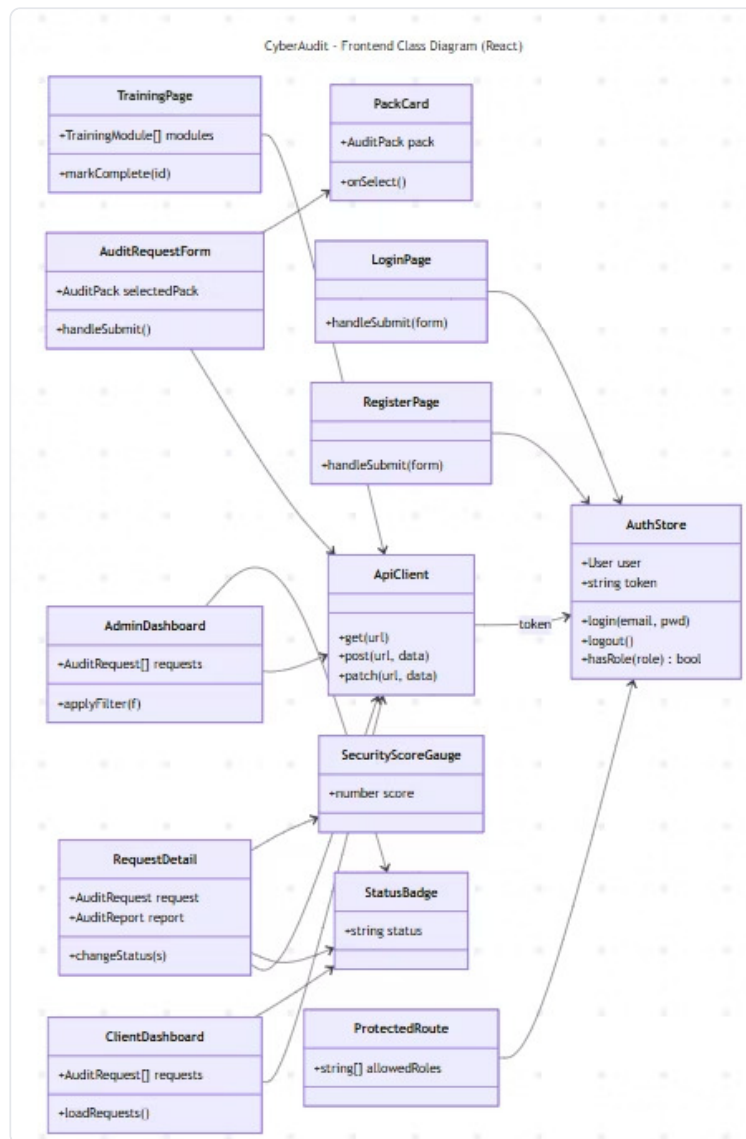


Figure 4 — Arborescence des composants React

Arborescence des composants

```

src/
├── components/
│   ├── auth/           LoginForm, RegisterForm, ProtectedRoute
│   ├── dashboard/      ClientDashboard, AdminDashboard, AuditRequestCard, StatusBadge
│   ├── audit/          AuditRequestForm, PackSelector, AuditDetailView
│   ├── training/       ModuleList, ModuleViewer
│   └── shared/         Header, Sidebar, Button, ErrorBoundary
├── pages/              HomePage, LoginPage, RegisterPage, DashboardPage,
                        NewAuditPage, AuditDetailPage, TrainingPage
├── hooks/              useAuth, useAudits, useApi
├── services/           api.js (axios + JWT), auth/audits/reports services
├── utils/              sanitize.js (DOMPurify), validators.js
└── App.jsx             routing global
  
```

Conventions : Composants fonctionnels + hooks (pas de classes), état global via Context API, sanitize() sur tous les inputs.

4.4 Génération du rapport PDF de vulnérabilités

Le rapport PDF est le livrable principal du client SME : il consolide l'analyse de vulnérabilités, le score de sécurité et le plan d'action recommandé. Sa génération est entièrement asynchrone pour ne pas bloquer l'interface admin.

Stack technique

- **WeasyPrint** : Convertit un template HTML+CSS en PDF de qualité impression. Réutilise la charte graphique du web.
- **Celery** : Exécute la tâche `generate_pdf_task` en arrière-plan.
- **Redis** : File d'attente Celery (scaling parallèle).
- **Stockage** : `/media/reports/` au MVP, S3 en V2 ; accès via URL signée 15 min.

Structure du PDF généré

Section	Contenu
Page 1 — Couverture	Logo CyberAudit, nom client, référence dossier (CYB-2026-0042), date, confidentialité
Page 2 — Synthèse exécutive	Score global A à F (jauge 0-100) + résumé en 3 lignes vulgarisées
Page 3 — Périmètre audité	Liste des actifs analysés (serveur mail, routeur Wi-Fi, postes...) + méthodologie EBIOS RM
Pages 4-N — Vulnérabilités	Tableau findings : sévérité (Critical/High/Medium/Low), actif, description, recommandation
Page finale — Plan d'action 30 jours	Étapes hebdomadaires (S1, S2, S3, S4) avec actions concrètes et priorités
Annexe	Glossaire, références (ISO 27005, ANSSI), contact CyberAudit

Flux complet — de la demande au téléchargement

1. L'admin clique sur « Generate PDF report » dans `AdminRequestDetail`.
2. Le front appelle `POST /api/requests/{id}/generate-report` avec les findings.
3. Le `PdfReportService` Django crée l'enregistrement `AuditReport` (résumé, score, findings JSON).
4. Il enfile la tâche `generate_pdf_task.delay(report_id)` et retourne `202 Accepted`.
5. Le worker Celery rend `report.html` avec les données, puis WeasyPrint produit le PDF.
6. Fichier sauvegardé dans `/media/reports/CYB-2026-0042.pdf`, `pdf_path` mis à jour.
7. Notification de type `report_ready` créée, e-mail envoyé via `send_email_task`.
8. Côté client, `ClientDashboard` affiche « Download report » → `GET /api/reports/{id}/download` en streaming.

Sécurité d'accès au PDF

- **JWT obligatoire** sur `/api/reports/{id}/download`. Aucun accès anonyme.
- **Permission** `IsAdminOrOwner` : 403 Forbidden sinon.
- **URL signée** avec timestamp, expire après 15 minutes.
- **Pas de cache navigateur** : `Cache-Control: no-store, private`.

- **Audit log** (V2) : qui, quand, depuis quelle IP — conforme RGPD.

Gestion des échecs de génération

- **Retry automatique** : `autoretry_for=(Exception,)` , `max_retries=3` , backoff exponentiel (10s, 30s, 90s).
- **Statut intermédiaire** : `pdf_path` vide tant que non généré → front affiche « Génération en cours... ».
- **Notification d'échec** : après 3 échecs, type `generation_failed` envoyée à l'admin.
- **Régénération manuelle** via le bouton « Generate PDF report ».

4.5 Monitoring & observabilité

L'application doit rester traçable en production : on doit savoir *qui a fait quoi, quand, et pourquoi ça a planté*. La stratégie repose sur 3 piliers : logs structurés, monitoring d'erreurs, alerting.

4.5.1 Logs structurés (JSON)

Django configure `structlog` pour produire des logs JSON consommables par Railway et un futur ELK/Loki. Chaque log porte au minimum : `timestamp` , `level` , `request_id` (corrélation), `user_id` , `endpoint` , `latency_ms` .

```
{
  "timestamp": "2026-05-18T09:24:11Z",
  "level": "INFO",
  "event": "audit_request.created",
  "request_id": "req-7f2a...",
  "user_id": "8f2a...c9",
  "audit_id": "CYB-2026-0042",
  "pack": "security",
  "latency_ms": 142
}
```

4.5.2 Monitoring d'erreurs — Sentry

- **Back-end** : `sentry-sdk[django,celery]` capture toutes les exceptions Django et Celery avec stack trace, context utilisateur, payload de la requête (PII anonymisée).
- **Front-end** : `@sentry/react` capture les erreurs JS et les rejets de promesse non gérés, plus les sessions replay sur erreur.
- **Release tracking** : chaque tag git pousse une release Sentry → suivi de régression par version.
- **Sample rate** : 100 % des erreurs en MVP ; 10 % des transactions performance pour rester dans le quota gratuit.

4.5.3 Métriques business & techniques

Métrique	Source	Seuil d'alerte
Temps de réponse API (p95)	Sentry Performance / Railway metrics	> 800 ms pendant 5 min
Taux d'erreur 5xx	Sentry	> 1 % sur 10 min
Échecs Celery consécutifs	Logs structurés	≥ 3 sur la même tâche

Métrique	Source	Seuil d'alerte
Connexions BDD actives	Railway Postgres metrics	> 80 % du pool
Espace disque /media	Railway	> 85 %
Demandes d'audit / jour	Django + dashboard admin	Métrique de croissance, pas d'alerte

4.5.4 Alerting

- **Sentry** envoie un e-mail au référent technique sur toute nouvelle erreur non vue, et un Slack DM (V2) si taux d'erreur > seuil.
- **Healthcheck** : endpoint `GET /api/health/` vérifie BDD, Redis, SMTP. Surveillé par UptimeRobot (gratuit) toutes les 5 min.
- **Notification d'échec Celery** : après 3 retries, un e-mail admin est envoyé (déjà documenté en §4.4).

4.5.5 Audit log applicatif (V2)

Une table `AUDIT_LOG` trace les actions sensibles : connexions, téléchargement de rapport, changement de statut, suppression de compte. Champs : `id`, `user_id`, `action`, `resource`, `ip`, `user_agent`, `created_at`. Conservation 1 an, conforme RGPD (cf. §7.5).

5. Diagrammes de séquence

5.1 Inscription + Connexion JWT

L'utilisateur saisit son email et son mot de passe. Le front appelle `POST /api/auth/register/`, puis `POST /api/auth/login/`. Django valide les credentials, génère access + refresh tokens, et retourne le tout au front. Le front stocke les tokens dans AuthStore et redirige vers le dashboard correspondant au rôle.

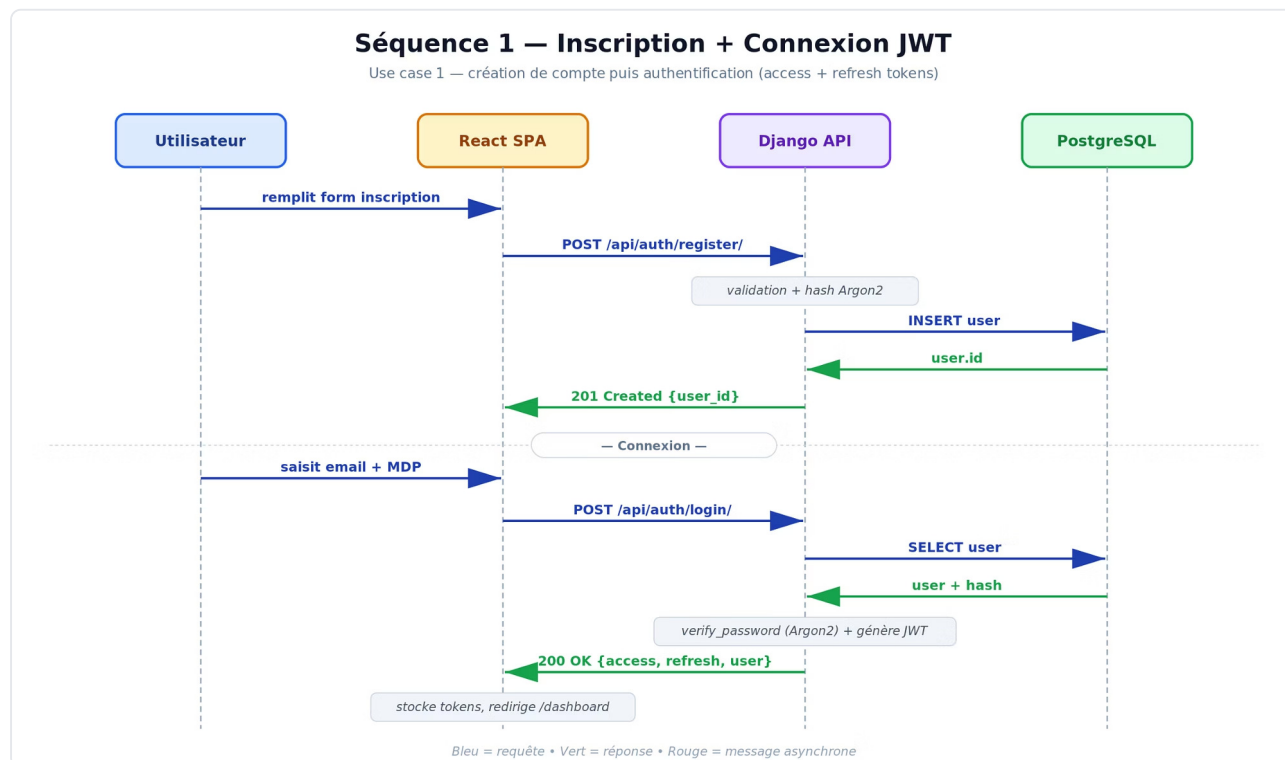


Figure 5 — Séquence Inscription + Connexion JWT

5.2 Soumission demande d'audit (avec async)

Le client soumet le formulaire d'audit. Le front appelle `POST /api/audits/` avec le JWT en header. Django valide via le serializer DRF, persiste en BDD, enfile une tâche Celery d'envoi d'accusé de réception, puis répond `201 Created`. Le worker Celery dépile la tâche depuis Redis et envoie l'e-mail via SMTP.

Séquence 2 — Soumission d'une demande d'audit

Use case 2 — flux asynchrone : réponse immédiate au client + email envoyé en arrière-plan

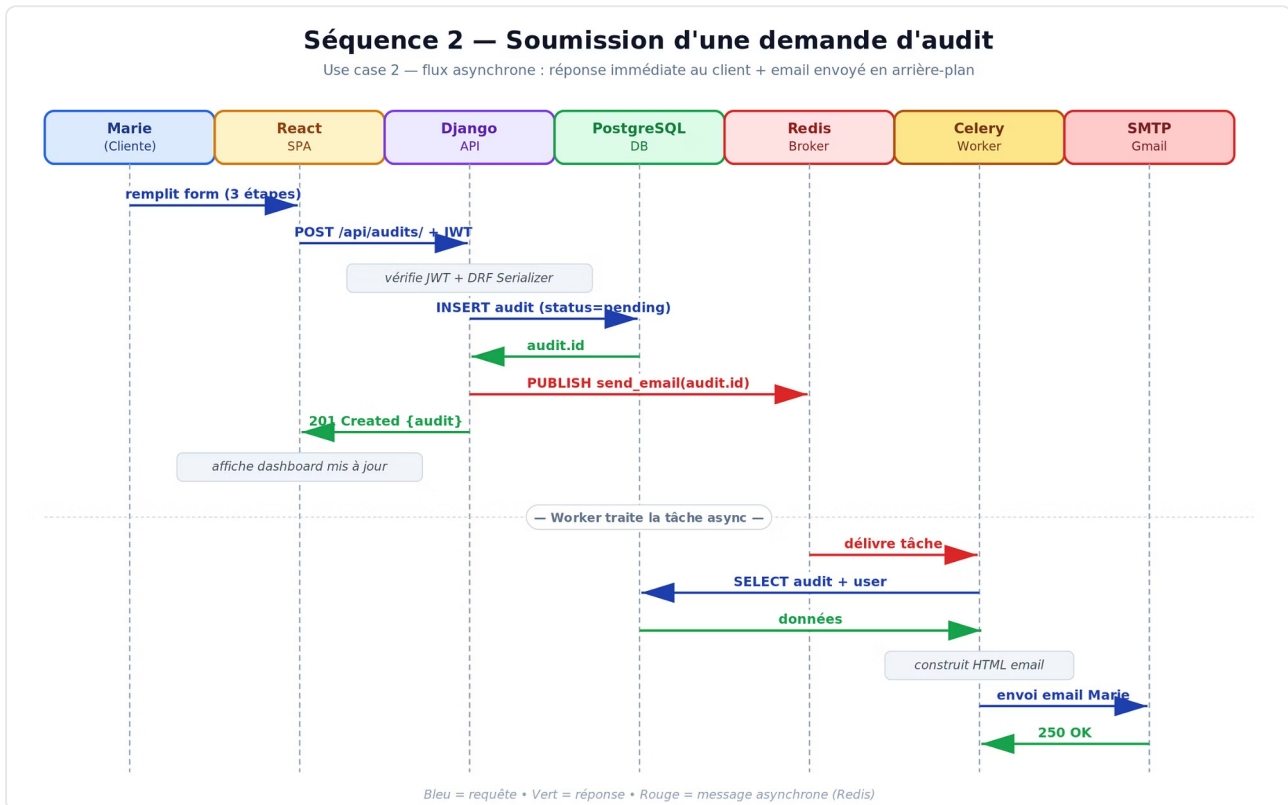


Figure 6 — Séquence Soumission demande (asynchrone Celery)

5.3 Génération du rapport PDF (admin)

L'admin clique sur « Generate PDF report ». Le front appelle `POST /api/audits/{id}/generate-report/`. Django crée l'`AuditReport` et enfile la tâche Celery, retournant `202 Accepted`. Le worker Celery rend le template HTML, WeasyPrint produit le PDF, le fichier est stocké, et une notification e-mail est envoyée au client.

Séquence 3 — Génération du rapport PDF (admin)

Use case 3 — l'admin déclenche, le worker génère, le client est notifié et récupère

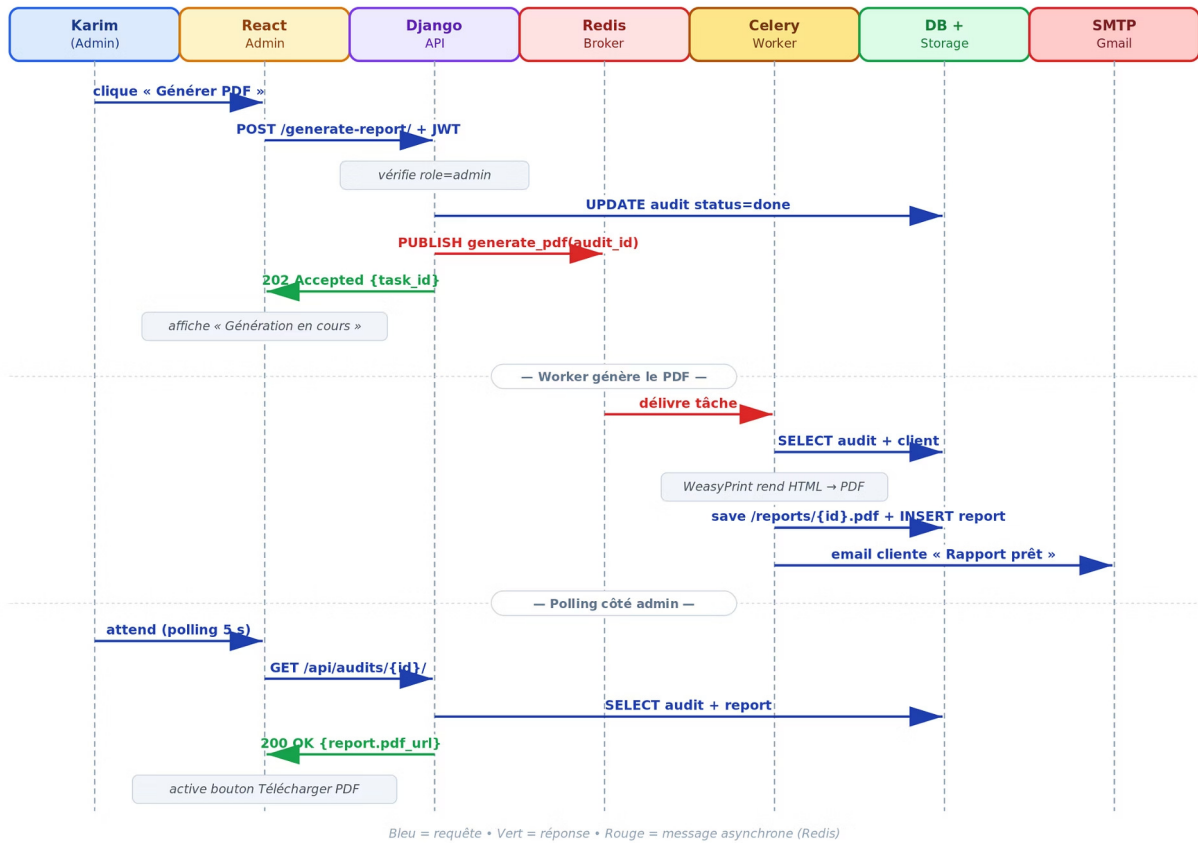


Figure 7 — Séquence Génération du rapport PDF

6. Documentation des APIs

6.1 APIs externes consommées

API externe	Usage	Justification
SMTP Gmail	Envoi des emails transactionnels (confirmation, changement statut, livraison rapport)	Gratuit jusqu'à 500 emails/jour, configuration simple, fiable. Migration possible vers SendGrid/Mailgun en V2.
Let's Encrypt	Certificats HTTPS automatiques	Gratuit, intégré nativement dans Vercel et Railway.

6.2 API interne — Endpoints REST

Convention : préfixe `/api/`, JSON pour requêtes et réponses, JWT dans `Authorization: Bearer <token>`, codes HTTP standards.

6.2.1 Authentification — `/api/auth/`

Méthode	URL	Auth	Description	Body	Réponse 2xx	Erreurs
POST	<code>/api/auth/register/</code>	—	Crée un compte client	{email, password, company_name, company_size, sector}	201 {user, access, refresh}	400, 409 email exists
POST	<code>/api/auth/login/</code>	—	Connexion + tokens JWT	{email, password}	200 {access, refresh, user}	401, 429 rate limit
POST	<code>/api/auth/refresh/</code>	—	Renouvelle access	{refresh}	200 {access}	401 refresh expired
POST	<code>/api/auth/logout/</code>	✓	Invalide le refresh	{refresh}	204	401
POST	<code>/api/auth/password-reset/</code>	—	Envoie email de reset	{email}	200 (toujours, anti-leak)	—

6.2.2 Demandes d'audit — `/api/audits/`

Méthode	URL	Auth	Rôle	Description
GET	<code>/api/audits/</code>	✓	client / admin	Liste paginée (client → ses demandes / admin → toutes)
POST	<code>/api/audits/</code>	✓	client	Crée une nouvelle demande

Méthode	URL	Auth	Rôle	Description
GET	/api/audits/{id}/	✓	owner / admin	Détail d'une demande
PATCH	/api/audits/{id}/	✓	admin	Modifie statut ou notes
DELETE	/api/audits/{id}/	✓	admin	Archive (soft delete)
POST	/api/audits/{id}/generate-report/	✓	admin	Lance la génération PDF (Celery)
GET	/api/audits/{id}/report/	✓	owner / admin	Télécharge le PDF (binaire)

Exemple — Création d'une demande

```
POST /api/audits/
Authorization: Bearer eyJhbGc...
Content-Type: application/json

{ "pack_id": 2, "scope_notes": "Audit du serveur de fichiers + 12 postes Windows." }

HTTP/1.1 201 Created
Content-Type: application/json

{
  "id": "8f2a...c9",
  "client": "user-uuid",
  "pack": {"id": 2, "name": "standard"},
  "status": "pending",
  "scope_notes": "Audit du serveur ...",
  "created_at": "2026-05-18T09:24:11Z"
}
```

6.2.3 Packs d'audit — /api/packs/

Méthode	URL	Auth	Description
GET	/api/packs/	—	Liste publique des 4 packs
GET	/api/packs/{id}/	—	Détail d'un pack

6.2.4 Formations — /api/training/

Méthode	URL	Auth	Description
GET	/api/training/modules/	✓	Liste des modules disponibles
GET	/api/training/modules/{id}/	✓	Contenu d'un module
POST	/api/training/modules/{id}/start/	✓	Marque comme commencé
POST	/api/training/modules/{id}/complete/	✓	Marque comme terminé

6.2.5 Profil utilisateur — `/api/users/`

Méthode	URL	Auth	Description
GET	<code>/api/users/me/</code>	✓	Profil de l'utilisateur courant
PATCH	<code>/api/users/me/</code>	✓	Modifie son propre profil
POST	<code>/api/users/me/change-password/</code>	✓	Change son mot de passe
DELETE	<code>/api/users/me/</code>	✓	Supprime son compte (RGPD)

6.3 Conventions transversales

- **Pagination** : `?page=1&page_size=20`, réponse `{count, next, previous, results}`
- **Filtres** : `?status=pending&ordering=-created_at`
- **Erreurs** : format unifié `{error: "code", message: "Message FR", details: {...}}`
- **Rate limiting** : 5 req/min sur `/auth/login/` et `/auth/password-reset/` (IP-based)
- **Versioning** : pas de v1 dans l'URL au MVP ; en V2 si breaking changes → `/api/v2/`

7. Stratégie SCM & QA

7.1 Source Code Management (Git)

Hébergeur : GitHub — repo `Tommy-JOUHANS/cyberaudit-solutions` (privé jusqu'à la soutenance, puis public).

Stratégie de branches (Git Flow allégé)

```
main          ← production uniquement (protégée, déploiement continu Vercel/Railway)
develop       ← branche d'intégration (CI obligatoire)
feature/<nom> ← nouvelles fonctionnalités (1 PR = 1 feature)
fix/<nom>      ← corrections de bugs
hotfix/<nom>   ← correctifs urgents directement sur main
release/<v>    ← stabilisation avant release (à partir de W11)
```

Convention de commits — Conventional Commits

```
feat(audits): ajout du formulaire de demande
fix(auth): corrige le refresh token JWT expiré
docs(readme): met à jour la stack technique
test(audits): ajoute tests unitaires CRUD
chore(deps): bump Django 5.0.2 → 5.0.3
refactor(reports): extrait PDFGenerator en service
```

Règles de Pull Request

Règle	Détail
Revue obligatoire	Chaque PR validée par l'autre membre avant merge
CI verte	Tests + lint OK avant merge
Pas de push direct	<code>main</code> et <code>develop</code> protégées par GitHub Branch Protection
Description structurée	« Ce qui change / Pourquoi / Comment tester »
Squash merge	1 PR = 1 commit dans <code>develop</code> (historique propre)

7.2 Stratégie QA

Pyramide de tests

```
      /\
     /E2E\      5 % - Cypress (parcours critiques)
    /-----\
   / Intégr. \ 20 % - Tests intégration API + DB (Django + DRF)
  /-----\
 / Unitaires  \ 75 % - Jest (front) + pytest (back)
/-----\
```

Outils retenus

Couche	Outil	Cible
Tests unitaires back	pytest + pytest-django	Modèles, services, serializers
Tests API back	pytest + APIClient (DRF)	Endpoints auth, audits, reports
Tests unitaires front	Jest + React Testing Library	Composants, hooks, utils
Tests E2E	Cypress	Inscription → demande → email (mock)
Tests sécurité	Postman (collection) + bandit	XSS, SQLi, brute-force, JWT tampering
Tests UX	3 sessions utilisateurs (W7-W10)	Persona Marie, parcours < 3 min
Coverage	coverage.py + jest --coverage	Cible : 80 % min apps critiques
Lint	ruff + black ; eslint + prettier	Pre-commit hook
Type checking	mypy ; propTypes ou TS (V2)	À partir de W4

7.3 Tests sécurité manuels (W7-W10)

Test	Méthode	Résultat attendu
XSS persistant	<code><script>alert(1)</script></code> dans scope_notes	Échappé / sanitized
SQL injection	<code>' OR 1=1 --</code> dans email login	Aucune fuite, ORM bind
Brute-force	100 tentatives login	Bloqué dès la 6 ^e (rate-limit)
JWT tampering	Modifier <code>role</code> dans le payload	Signature invalide → 401
CSRF	POST sans header Authorization	401
HSTS / CSP	Headers HTTP en prod	Présents et stricts

7.4 Pipeline CI/CD

GitHub Actions

```
# .github/workflows/ci.yml
name: CI
on: [push, pull_request]

jobs:
  backend:
    runs-on: ubuntu-latest
    steps:
      - checkout
      - setup-python 3.11
      - install: pip install -r backend/requirements-dev.txt
      - lint: ruff check . && black --check .
      - test: pytest --cov=apps --cov-fail-under=80
```

```

frontend:
  runs-on: ubuntu-latest
  steps:
    - checkout
    - setup-node 18
    - install: npm ci
    - lint: npm run lint
    - test: npm test -- --coverage
    - build: npm run build

```

Déploiement continu

Environnement	Déclencheur	Cible	URL
Preview	Toute PR	Vercel preview + Railway branch deploy	pr- XX.preview.cyberaudit.app
Staging	Merge sur develop	Vercel + Railway staging	staging.cyberaudit.app
Production	Merge sur main (release tag)	Vercel + Railway prod	cyberaudit.app

Stratégie de release

- **Versioning SemVer** : 0.1.0 (W4 MVP partiel) → 0.5.0 (W6 async) → 1.0.0 (W12 soutenance)
- **Tag git annoté** à chaque release : `git tag -a v1.0.0 -m "MVP soutenance Holberton"`
- **Changelog** tenu à jour dans `CHANGELOG.md`

7.5 Conformité RGPD

La plateforme traite des données personnelles (email, nom, entreprise) et des données sensibles (rapports de vulnérabilités). Le règlement (UE) 2016/679 (RGPD) impose un cadre strict que le MVP intègre dès la conception (*privacy by design*).

7.5.1 Registre des traitements

Traitement	Base légale	Données	Durée de conservation
Création de compte	Exécution contractuelle (art. 6.1.b)	email, nom, prénom, entreprise, mot de passe haché	Compte actif + 3 ans après dernière connexion
Soumission demande d'audit	Exécution contractuelle	périmètre, notes, pack choisi	3 ans à compter de la clôture du dossier (obligation comptable)
Génération rapport PDF	Exécution contractuelle	findings, score, recommandations	3 ans, puis suppression automatique
Notifications e-mail	Exécution contractuelle	destinataire, sujet, statut envoi	1 an (debug)
Logs d'accès & audit log	Intérêt légitime (art. 6.1.f) — sécurité	IP, user-agent, action, horodatage	1 an puis purge automatique

Traitement	Base légale	Données	Durée de conservation
Cookies non essentiels	Consentement (art. 6.1.a)	aucun en MVP — pas de tracking	—

7.5.2 Droits des personnes

Droit RGPD	Mise en œuvre
Accès (art. 15)	GET <code>/api/users/me/export/</code> retourne un JSON complet des données du compte. SLA : ≤ 30 jours.
Rectification (art. 16)	PATCH <code>/api/users/me/</code> permet la modification directe par l'utilisateur.
Effacement (art. 17 — "droit à l'oubli")	DELETE <code>/api/users/me/</code> déclenche une suppression en cascade : User, AuditRequest, AuditReport, Notification, TrainingProgress. PDF physiquement supprimés du stockage. Logs anonymisés (user_id remplacé par <code>deleted-user</code>) mais conservés pour intégrité légale.
Portabilité (art. 20)	Export JSON via <code>/api/users/me/export/</code> au format ouvert, réutilisable.
Opposition (art. 21)	Désactivation des e-mails non transactionnels via préférences utilisateur (V2).
Limitation (art. 18)	Champ <code>is_active=False</code> suspend l'accès sans supprimer le compte, sur demande.

7.5.3 Mesures techniques et organisationnelles

- **Chiffrement au repos** : Postgres Railway chiffré AES-256. PDFs stockés sur volume chiffré.
- **Chiffrement en transit** : HTTPS obligatoire (Let's Encrypt), HSTS activé avec `max-age=31536000`.
- **Hashage** : mots de passe via `bcrypt` (Django par défaut, 12 rounds), jamais stockés en clair.
- **Minimisation** : seules les données strictement nécessaires sont collectées (pas de date de naissance, pas de téléphone non requis).
- **Séparation des accès** : seuls les admins CyberAudit voient les rapports ; les autres clients sont totalement isolés (permission `IsOwner`).
- **Sous-traitants** : Railway (hébergement), Vercel (front), Gmail SMTP (envoi mails) — tous documentés comme sous-traitants au sens de l'art. 28 dans un registre interne.

7.5.4 Cookies & bannière de consentement

Le MVP n'utilise **aucun cookie tiers ni traceur publicitaire**. Seul un cookie technique de session (JWT) est posé, exempté de consentement (recommandation CNIL "cookies strictement nécessaires"). La bannière de consentement sera ajoutée en V2 si Google Analytics ou Plausible sont introduits.

7.5.5 Procédure en cas de violation de données

1. Détection via Sentry / monitoring / signalement utilisateur.
2. Confinement immédiat (révocation tokens, isolation BDD si nécessaire).
3. Évaluation du risque pour les personnes (gravité, nombre de personnes concernées).
4. Notification à la CNIL dans les **72 heures** (art. 33) via [notifications.cnil.fr](https://www.cnil.fr/fr/notifications).

5. Information des utilisateurs concernés si risque élevé (art. 34).
6. Documentation interne de l'incident dans le registre des violations.

7.5.6 Mentions légales & politique de confidentialité

Deux pages publiques accessibles depuis le footer : `/legal/mentions` (éditeur, hébergeur, contact) et `/legal/privacy` (politique de confidentialité reprenant les §7.5.1 à 7.5.5 en langage clair). Lien CNIL pour réclamation.

8. Annexes

8.1 Glossaire

Terme	Définition
MVP	Minimum Viable Product — version minimale livrable
JWT	JSON Web Token — standard d'authentification stateless
MoSCoW	Méthode de priorisation : Must / Should / Could / Won't
CRUD	Create / Read / Update / Delete
ORM	Object Relational Mapping — abstraction BDD
CI/CD	Continuous Integration / Continuous Deployment
RGPD	Règlement Général sur la Protection des Données
HSTS	HTTP Strict Transport Security — header anti-downgrade
CSP	Content Security Policy — header anti-XSS
SemVer	Semantic Versioning — MAJOR.MINOR.PATCH
SPA	Single Page Application

8.2 Mapping Stage 3 ↔ compétences RNCP 5

Référentiel RNCP 38038 — Développeur Web et Web Mobile (TP délivré par le Ministère du Travail).

Bloc RNCP	Compétence	Section
BC01 — Front-end	Maquetter une application	§2.3 (mockups)
BC01	Réaliser des interfaces statiques et dynamiques	§4.3 (composants React)
BC01	Développer la partie front-end	§3 (archi), §6 (API)
BC02 — Back-end	Créer une base de données	§4.1 (ERD)
BC02	Développer les composants d'accès aux données	§4.2 (modèles Django)
BC02	Développer la partie back-end	§6 (API REST)
BC02	Élaborer et mettre en œuvre des composants	§4.2 (services), §5 (séquences)
Transversal	Travailler en équipe agile / Versioning	§7 (SCM/QA)

8.3 Sources & références techniques

Référence	Lien
Django REST Framework — Documentation	https://www.django-rest-framework.org

Référence	Lien
SimpleJWT — JWT pour Django	https://django-rest-framework-simplejwt.readthedocs.io
Celery — Distributed Task Queue	https://docs.celeryq.dev
WeasyPrint — HTML to PDF	https://weasyprint.org
OWASP Top 10 — référentiel sécurité	https://owasp.org/www-project-top-ten
Conventional Commits	https://www.conventionalcommits.org
RNCP 38038	https://www.francecompetences.fr/recherche/rncp/38038
ANSSI — Panorama de la cybermenace 2023	https://www.ssi.gouv.fr

8.4 Matrice des risques projet

Analyse des risques techniques et opérationnels identifiés sur le périmètre MVP. Chaque risque est évalué selon sa probabilité (Faible / Moyenne / Élevée) et son impact (Faible / Moyen / Élevé), puis associé à une mitigation et un responsable.

ID	Risque	Probabilité	Impact	Mitigation	Responsable
R-01	Panne du worker Celery → PDF non générés	Moyenne	Élevé	Retry automatique (3×, backoff exponentiel) + notification admin après échec final + bouton « régénérer » manuel dans AdminRequestDetail. Healthcheck UptimeRobot toutes les 5 min.	James
R-02	Fuite de données personnelles (rapport PDF leaké, fuite BDD)	Faible	Élevé	URL signées 15 min, JWT obligatoire, permission <code>IsAdminOrOwner</code> , audit log (§4.5), procédure de notification CNIL en 72 h documentée (§7.5.5).	Tommy + James
R-03	Perte de données BDD (corruption, suppression accidentelle)	Faible	Élevé	Backups Railway automatiques quotidiens (rétention 7 jours sur le plan gratuit, 30 jours en V2). Snapshot manuel avant chaque migration en prod. Tests de restauration en W10.	James
R-04	Attaque par force brute sur <code>/auth/login/</code>	Moyenne	Moyen	Rate limiting 5 req/min par IP, verrouillage temporaire après 5 échecs, alerte Sentry au-delà de 50 échecs/h sur une même IP. Tests E2E couvrant le scénario (§7.3).	James
R-05	XSS persistant via <code>scope_notes</code> ou contenu Markdown des formations	Moyenne	Élevé	DOMPurify côté front, échappement Django côté back, CSP stricte (<code>script-src 'self'</code>). Tests sécurité manuels W7-W10 (§7.3).	Tommy

ID	Risque	Probabilité	Impact	Mitigation	Responsable
R-06	Quota Gmail SMTP atteint (500 mails/jour)	Moyenne	Moyen	Surveillance compteur quotidien. Migration vers SendGrid (gratuit jusqu'à 100/jour, payant au-delà) ou Mailgun dès que volume > 400/jour. File de secours Celery pour ne pas perdre les mails.	James
R-07	Retard sur le planning W12 (soutenance Holberton)	Moyenne	Élevé	Périmètre Must-Have figé en W3, Should-Have négociables, Could-Have hors MVP. Points hebdomadaires Tommy/James. Buffer d'1 semaine prévu en W11 pour stabilisation.	Tommy
R-08	Indisponibilité d'un des 2 devs (maladie, examen)	Faible	Moyen	Pair-programming sur les zones critiques (auth, génération PDF). Documentation à jour permettant la reprise. Tâches Trello/GitHub Project assignées et priorisées.	Tommy + James
R-09	Régression majeure après déploiement prod	Faible	Élevé	Pipeline CI/CD obligatoire (lint + tests + coverage 80 %), déploiement staging avant prod, rollback Railway/Vercel en 1 clic, monitoring Sentry release par release.	James
R-10	Non-conformité RGPD relevée par le jury / CNIL	Faible	Élevé	Section §7.5 dédiée, mentions légales et politique de confidentialité en ligne dès W6, droit à l'oubli implémenté avant la soutenance, registre des traitements à jour.	Tommy
R-11	Score Lighthouse Accessibilité < 90	Moyenne	Moyen	Lighthouse CI bloquant dans GitHub Actions, axe-core dans les tests unitaires, audit manuel NVDA + clavier en W8 (§3.4). Itérations rapides avant la soutenance.	Tommy
R-12	Coût d'hébergement non maîtrisé en V2	Faible	Faible	Plans gratuits Railway et Vercel suffisants pour le MVP et la soutenance. Bascule vers offre payante uniquement si lancement commercial.	Tommy

8.4.1 Tableau de criticité

Croisement probabilité × impact pour visualiser les priorités :

	Impact Faible	Impact Moyen	Impact Élevé
Proba Élevée	—	—	—
Proba Moyenne	—	R-04, R-06, R-11	R-01, R-05, R-07
Proba Faible	R-12	R-08	R-02, R-03, R-09, R-10

Les **3 risques critiques** à traiter en priorité (Proba Moyenne × Impact Élevé) sont R-01 (Celery), R-05 (XSS) et R-07 (planning).

8.5 Liens internes au projet

- Stage 1 — Charte projet (FR)
- Stage 2 — Planning & Gantt (FR)
- Wireframes Figma — à publier en W1 par Tommy
- Repo code MVP — à initialiser en W2

Document préparé dans le cadre du Stage 3 — Documentation technique, Holberton School Dijon, promotion 2026.
Conçu pour être réutilisé tel quel dans le dossier de certification RNCP 5 — Développeur Web et Web Mobile.

Tommy JOUHANS — Chef de projet / Développeur Front-End • **James ROUSSEL** — Référent technique / Développeur Back-End